

MAINCRAFTS TECHNOLOGY

Vulnerability Assessment Report

Cybersecurity Internship — Task-3: Vulnerability Scanning & Assessment

Prepared by: Benidict David

Date: July 7, 2026

Classification: Internal / Lab Use Only

1. Executive Summary

This report documents a vulnerability assessment performed against two intentionally vulnerable lab targets: Metasploitable2 (legacy Linux VM) and OWASP Juice Shop (containerized modern web application), both hosted on an isolated VirtualBox lab network (192.168.56.0/24). The assessment was conducted as Task-3 of the Maincrafts Technology cybersecurity internship, using Nmap, Nikto, and Dirsearch for network and web-layer reconnaissance.

The assessment identified a mix of critical legacy misconfigurations on Metasploitable2 — including a known backdoored FTP service, an IRC daemon with a documented backdoor, cleartext remote-access protocols, and default administrative credentials on Apache Tomcat — alongside lower-severity but still notable issues on Juice Shop, including a wildcard CORS policy, absent security headers, and an observed denial-of-service condition triggered simply by directory brute-forcing at default thread counts.

No exploitation was performed. All findings below were obtained through passive/active scanning only, consistent with the scope defined for Task-3. Exploitation is scheduled for Task-4.

Overall risk posture: Metasploitable2 is intentionally critical-risk by design (it exists to teach these exact weaknesses). Juice Shop's findings are lower in severity individually, but the absence of rate limiting is a legitimate operational concern even in a training context, since it demonstrates how easily automated scanning degrades an unprotected Node.js application.

2. Methodology

Testing followed the scope and workflow defined in the Task-3 brief. No exploit attempts, denial-of-service actions, or testing of systems outside the lab network were performed.

2.1 Scope

In-Scope	Out-of-Scope
Lab systems only (192.168.56.0/24)	Anything outside the lab network
Passive and active scanning	Exploit attempts
Web and network-layer visible issues	Intentional system destruction / DoS

2.2 Tools Used

Tool	Purpose	Version
Nmap	Host discovery, port and service/version enumeration	7.99
Nikto	Web server misconfiguration and outdated-component detection	v2.6.0
Dirsearch	Hidden file/directory discovery via wordlist brute-force	v0.4.3

2.3 Targets

Target	IP / Host	Description
Target 1	192.168.56.103	Metasploitable2 — intentionally vulnerable Ubuntu 8.04-based Linux VM
Target 2	127.0.0.1:3000 (Docker)	OWASP Juice Shop — containerized modern Node.js/Angular web application, running on the Kali attacker host

2.4 Rules of Engagement

- All testing conducted within an isolated Host-Only VirtualBox network (192.168.56.0/24); no traffic left the lab.
- Both targets were systems the assessor personally deployed and owned in Task-2 — no third-party or production assets were touched.
- Scans were run sequentially, not concurrently, to avoid conflating results between targets.

3. Host Discovery

An initial ping sweep across the lab subnet confirmed four live hosts: the VirtualBox Host-Only gateway (192.168.56.1), the Windows host adapter (192.168.56.100), Metasploitable2 (192.168.56.103), and a fourth VirtualBox-managed host (192.168.56.102). Metasploitable2 was confirmed reachable and selected as Target 1.

```
(benidict@benny)-[~/intern]
$ cd ~/intern
python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.56.1 - - [06/Jul/2026 17:45:50] "GET /metasploitable2.zip HTTP/1.1" 200 -
^C
Keyboard interrupt received, exiting.

(benidict@benny)-[~/intern]
$ nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 18:06 +0530
Nmap scan report for 192.168.56.1
Host is up (0.00051s latency).
MAC Address: 0A:00:27:00:00:11 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00062s latency).
MAC Address: 08:00:27:16:6C:C0 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0011s latency).
MAC Address: 08:00:27:FC:A5:DF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 4.27 seconds
```

Figure 1 — nmap -sn host discovery sweep confirming 192.168.56.103 is live

4. Technical Findings — Target 1: Metasploitable2 (192.168.56.103)

4.1 Port & Service Enumeration

A full TCP port/service scan (`nmap -sV -p-`) identified 30 open ports. The service versions returned are, without exception, deliberately outdated builds shipped with Metasploitable2 for training purposes — several correspond to publicly documented CVEs.

```
(benidict@benny)-[~/intern]
$ nmap -sV -p- 192.168.56.103 -oN ~/lab/scans/metasploitable-portscan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 18:06 +0530
Nmap scan report for 192.168.56.103
Host is up (0.00078s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
40653/tcp open  java-rmi     GNU Classpath grmiregistry
44605/tcp open  nlockmgr     1-4 (RPC #100021)
58167/tcp open  status       1 (RPC #100024)
60153/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:FC:A5:DF (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 141.46 seconds

(benidict@benny)-[~/intern]
```

Figure 2 — Full port/service scan output (`nmap -sV -p-`), 30 open ports identified

Port	Service	Version	Notable Issue
21/tcp	ftp	vsftpd 2.3.4	Publicly documented backdoored build (CVE-2011-2523)
23/tcp	telnet	Linux telnetd	Cleartext remote administration protocol
512-514/tcp	exec/login/shell	Netkit rsh/rlogin/rexec	Cleartext r-services; trust-based auth
6667/6697	irc	UnrealIRCd	Publicly documented backdoored build (CVE-2010-2075)
8180/tcp	http	Apache Tomcat/Coyote 1.1	Default manager credentials present (see 4.3)
3306/tcp	mysql	5.0.51a-3ubuntu5	End-of-life MySQL release
2049/tcp	nfs	2-4	Frequently misconfigured for anonymous export access

Port	Service	Version	Notable Issue
139/445/tcp	smb	Samba 3.X-4.X	Legacy Samba, historically CVE-rich (e.g. CVE-2007-2447)

4.2 Nikto — Port 80 (Apache/PHP)

Nikto identified an outdated Apache 2.2.8 (Ubuntu) / PHP 5.2.4 stack, both multiple major versions behind current releases at time of writing. HTTP TRACE method was enabled (Cross-Site Tracing risk), directory indexing was active on /icons/ and /doc/, and a browsable /doc/ directory was flagged as CVE-1999-0678. Standard hardening headers (CSP, HSTS, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) were absent.

```
(benidict@benny) [~/intern]
$ nikto -h http://192.168.56.103:80 -o ~/lab/scans/metasploitable-nikto-80.txt
nikto -h http://192.168.56.103:8180 -o ~/lab/scans/metasploitable-nikto-8180.txt

dirsearch -u http://192.168.56.103:80 -o ~/lab/scans/metasploitable-dirsearch-80.txt
dirsearch -u http://192.168.56.103:8180 -o ~/lab/scans/metasploitable-dirsearch-8180.txt
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-07-06 18:13:46 (GMT5.5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPB885F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via a HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHP9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?PHP9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?PHP9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
```

Figure 3 — Nikto scan of port 80: outdated Apache/PHP, TRACE enabled, missing headers

4.3 Nikto — Port 8180 (Apache Tomcat)

The Tomcat instance on port 8180 disclosed its version range via favicon fingerprinting (Tomcat 5.5.26–8.0.15 / Coyote 1.1) and — most significantly — Nikto confirmed a default account for the 'Tomcat Manager Application' (credentials tomcat/tomcat) at ID 'tomcat', tracked under CWE-16 (Configuration). The Tomcat Server Administration interface was also directly reachable at /admin/login.jsp.


```

benidict@benny: ~/fintern
Session Actions Edit View Help
nsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to au
thorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header wi
th the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-
Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content o
f the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulne
rabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-07-06 18:19:52 (GMT5.5) (366 seconds)

+ 1 host(s) tested
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 8180
+ Platform: Unknown
+ Start Time: 2026-07-06 18:19:53 (GMT5.5)

+ Server: Apache-Coyote/1.1
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [500645] /favicon.ico: identifies this app/server as: Apache Tomcat (possibly 5.5.26 through 8.0.15), Alfresco Co
mmunity. See: https://en.wikipedia.org/wiki/Favicon
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-U
S/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/
Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/
docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/d
ocs/Web/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000356] /: Appears to be a default Apache Tomcat install.
+ [95] /admin/: Cookie JSESSIONID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/
Web/HTTP/Cookies
+ [002785] /tomcat-docs/index.html: Default Apache Tomcat documentation found. See: CWE-552
+ [003489] /webdav/index.html: WebDAV support is enabled.
+ [003502] /jsp-examples/: Apache Java Server Pages documentation. See: CWE-552
+ [006437] /servlets-examples/: Tomcat servlets examples are visible.
+ [700124] /manager/html: Default account found for 'Tomcat Manager Application' at (ID 'tomcat', PW 'tomcat'). Apa
che Tomcat. See: CWE-16
+ [007017] /admin/login.jsp: Tomcat Server Administration interface found.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header wi
th the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-
Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content o
f the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulne
rabilities/missing-content-type-header/
+ 8346 requests: 0 errors and 17 items reported on the remote host
+ End Time: 2026-07-06 18:21:17 (GMT5.5) (84 seconds)

+ 1 host(s) tested

```

Figure 4 — Nikto scan of port 8180: default Tomcat Manager credentials confirmed

4.4 Dirsearch — Port 80

Directory brute-forcing against port 80 surfaced several additional vulnerable-by-design applications co-hosted on the same web root, confirming this host serves as a shared training target: /dvwa/ (Damn Vulnerable Web Application), /mutillidae/, /tikiwiki/, /phpinfo (full PHP configuration disclosure), and an exposed /phpMyAdmin/ database management panel.

```

benidict@benny: ~/intern
Session Actions Edit View Help

dirsearch v0.4.3
Extensions: php, asp, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/benidict/lab/scans/metasploitable-dirsearch-80.txt
Target: http://192.168.56.103/

[18:21:18] Starting:
[18:21:21] 403 - 298B - /.ht_wsr.txt
[18:21:21] 403 - 301B - /.htaccess.bak1
[18:21:21] 403 - 301B - /.htaccess.orig
[18:21:21] 403 - 303B - /.htaccess.sample
[18:21:21] 403 - 301B - /.htaccess.save
[18:21:21] 403 - 302B - /.htaccess_extra
[18:21:21] 403 - 299B - /.htaccess_sc
[18:21:21] 403 - 301B - /.htaccess_orig
[18:21:21] 403 - 299B - /.htaccessOLD
[18:21:21] 403 - 299B - /.htaccessBAK
[18:21:21] 403 - 300B - /.htaccessOLD2
[18:21:21] 403 - 291B - /.htm
[18:21:21] 403 - 292B - /.html
[18:21:21] 403 - 297B - /.htpasswd
[18:21:21] 403 - 301B - /.htpasswd_test
[18:21:21] 403 - 298B - /.htpasswd_oauth
[18:21:39] 403 - 295B - /cgi-bin/
[18:21:43] 200 - 111KB - /doc/
[18:21:43] 302 - 0B - /dvwa/ → login.php
[18:21:53] 200 - 24KB - /mutillidae/
[18:21:56] 200 - 49KB - /phpinfo
[18:21:56] 200 - 49KB - /phpinfo.php
[18:21:56] 301 - 326B - /phpMyAdmin → http://192.168.56.103/phpMyAdmin/
[18:21:57] 200 - 4KB - /phpMyAdmin/index.php
[18:21:57] 200 - 4KB - /phpMyAdmin/
[18:22:01] 403 - 300B - /server-status
[18:22:01] 403 - 301B - /server-status/
[18:22:07] 301 - 320B - /test → http://192.168.56.103/test/
[18:22:07] 200 - 885B - /test/
[18:22:08] 301 - 324B - /tikiwiki → http://192.168.56.103/tikiwiki/

Task Completed
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API
. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

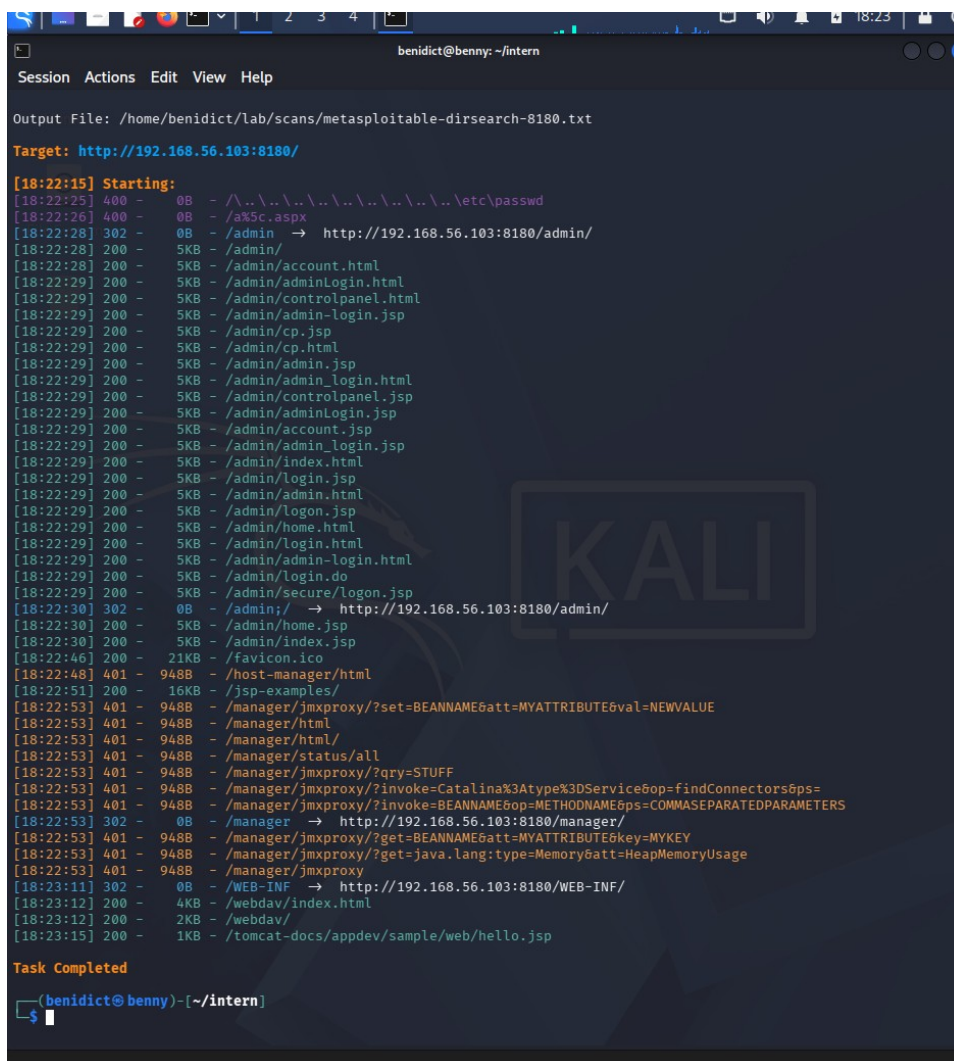
dirsearch v0.4.3
Extensions: php, asp, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/benidict/lab/scans/metasploitable-dirsearch-8180.txt
Target: http://192.168.56.103:8180/
[18:22:15] Starting:

```

Figure 5 — Dirsearch against port 80: DVWA, Mutillidae, phpMyAdmin, phpinfo exposed

4.5 Dirsearch — Port 8180 (Tomcat)

Against the Tomcat instance, Dirsearch enumerated a broad set of reachable admin/login endpoints (`/admin/`, `/manager/`, `/host-manager/`, `/webdav/`) and multiple JMX-proxy invocation paths under `/manager/jmxproxy/*`, which — combined with the confirmed default credentials in 4.3 — represent a direct path to full application-server compromise if left unremediated. A path traversal probe (`../../../../etc/passwd`) was attempted by the tool automatically and correctly rejected (HTTP 400), indicating basic input handling is intact at that specific endpoint.



```

benidict@benny: ~/intern
Session Actions Edit View Help

Output File: /home/benidict/lab/scans/metasploitable-dirsearch-8180.txt

Target: http://192.168.56.103:8180/

[18:22:15] Starting:
[18:22:25] 400 - 0B - / \.. \.. \.. \.. \.. \.. \.. \.. \etc\passwd
[18:22:26] 400 - 0B - /a%5c.aspx
[18:22:28] 302 - 0B - /admin → http://192.168.56.103:8180/admin/
[18:22:28] 200 - 5KB - /admin/
[18:22:28] 200 - 5KB - /admin/account.html
[18:22:29] 200 - 5KB - /admin/adminLogin.html
[18:22:29] 200 - 5KB - /admin/controlpanel.html
[18:22:29] 200 - 5KB - /admin/admin-login.jsp
[18:22:29] 200 - 5KB - /admin/cp.jsp
[18:22:29] 200 - 5KB - /admin/cp.html
[18:22:29] 200 - 5KB - /admin/admin.jsp
[18:22:29] 200 - 5KB - /admin/admin_login.html
[18:22:29] 200 - 5KB - /admin/controlpanel.jsp
[18:22:29] 200 - 5KB - /admin/adminLogin.jsp
[18:22:29] 200 - 5KB - /admin/account.jsp
[18:22:29] 200 - 5KB - /admin/admin_login.jsp
[18:22:29] 200 - 5KB - /admin/index.html
[18:22:29] 200 - 5KB - /admin/login.jsp
[18:22:29] 200 - 5KB - /admin/admin.html
[18:22:29] 200 - 5KB - /admin/logon.jsp
[18:22:29] 200 - 5KB - /admin/home.html
[18:22:29] 200 - 5KB - /admin/login.html
[18:22:29] 200 - 5KB - /admin/admin-login.html
[18:22:29] 200 - 5KB - /admin/login.do
[18:22:29] 200 - 5KB - /admin/secure/logon.jsp
[18:22:30] 302 - 0B - /admin;/ → http://192.168.56.103:8180/admin/
[18:22:30] 200 - 5KB - /admin/home.jsp
[18:22:30] 200 - 5KB - /admin/index.jsp
[18:22:46] 200 - 21KB - /favicon.ico
[18:22:48] 401 - 948B - /host-manager/html
[18:22:51] 200 - 16KB - /jsp-examples/
[18:22:53] 401 - 948B - /manager/jmxproxy/?set=BEANNAME&att=MYATTRIBUTE&val=NEWVALUE
[18:22:53] 401 - 948B - /manager/html
[18:22:53] 401 - 948B - /manager/html/
[18:22:53] 401 - 948B - /manager/status/all
[18:22:53] 401 - 948B - /manager/jmxproxy/?qry=STUFF
[18:22:53] 401 - 948B - /manager/jmxproxy/?invoke=Catalina%3Atype%3DService&op=findConnectors&ps=
[18:22:53] 401 - 948B - /manager/jmxproxy/?invoke=BEANNAME&op=METHODNAME&ps=COMMASEPARATEDPARAMETERS
[18:22:53] 302 - 0B - /manager → http://192.168.56.103:8180/manager/
[18:22:53] 401 - 948B - /manager/jmxproxy/?get=BEANNAME&att=MYATTRIBUTE&key=MYKEY
[18:22:53] 401 - 948B - /manager/jmxproxy/?get=java.lang:type=Memory&att=HeapMemoryUsage
[18:22:53] 401 - 948B - /manager/jmxproxy
[18:23:11] 302 - 0B - /WEB-INF → http://192.168.56.103:8180/WEB-INF/
[18:23:12] 200 - 4KB - /webdav/index.html
[18:23:12] 200 - 2KB - /webdav/
[18:23:15] 200 - 1KB - /tomcat-docs/appdev/sample/web/hello.jsp

Task Completed

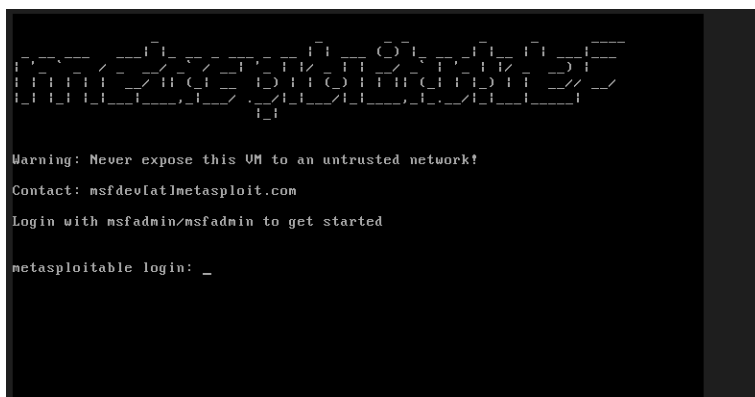
(benidict@benny) - (~ / intern)
$

```

Figure 6 — Dirsearch against port 8180: Tomcat admin/manager endpoints enumerated

4.6 Evidence — Host Access Confirmation

The following screenshots confirm direct console access to the Metasploitable2 VM was available for verification purposes (used only to confirm host identity/IP configuration — no credentialed exploitation was performed against services).



```

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: _

```

Figure 7 — Metasploitable2 login banner


```

Last login: Sun May 20 15:50:42 EDT 2012 from 172.16.123.1 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig eth0
eth0      Link encap:Ethernet HWaddr 08:00:27:fc:a5:df
          inet addr:192.168.56.103 Bcast:192.168.56.255 Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fefc:a5df/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:8 errors:0 dropped:0 overruns:0 frame:0
          TX packets:57 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2632 (2.5 KB)  TX bytes:8734 (8.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

msfadmin@metasploitable:~$ _

```

Figure 8 — Console confirmation of IP 192.168.56.103 via ifconfig

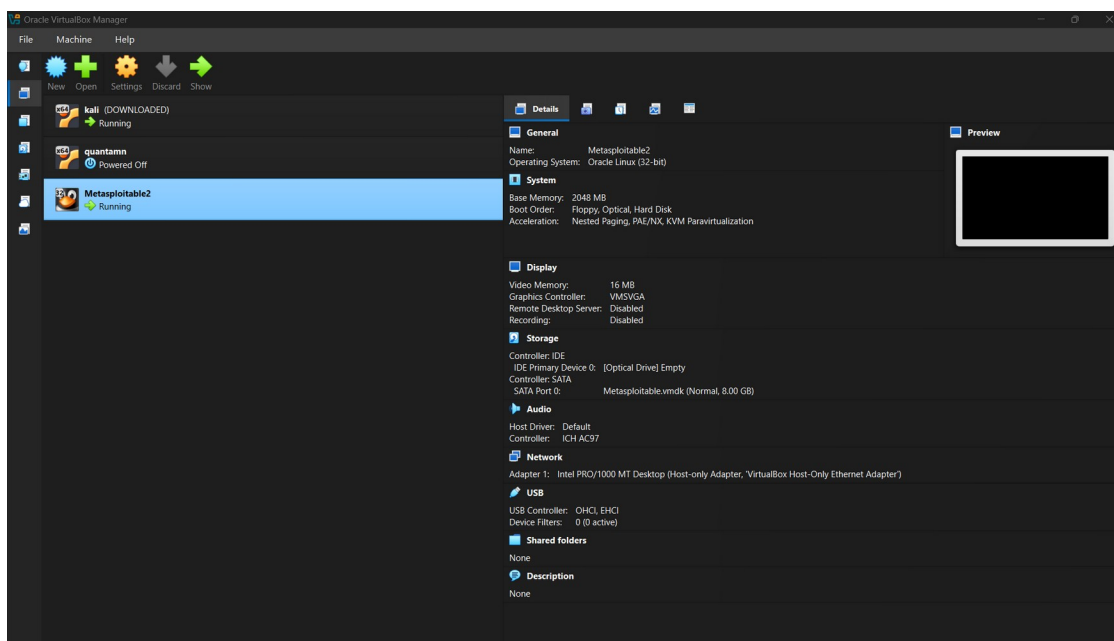


Figure 9 — VirtualBox Manager showing Metasploitable2 VM running with Host-Only networking

5. Technical Findings — Target 2: OWASP Juice Shop (127.0.0.1:3000)

Juice Shop is a modern Node.js/Express/Angular single-page application (SPA), deployed via Docker on the Kali attacker host itself rather than as a separate network host. Its architecture differs substantially from Metasploitable2: there is no legacy CGI surface, and its Angular routing returns HTTP 200 for almost any client-side path (a catch-all pattern), which materially affects how scanner output must be interpreted — addressed explicitly below to avoid over-reporting false positives.

5.1 Service Confirmation & HTTP Header Analysis

Nmap's service-version probe against port 3000 could not confidently fingerprint the service (returned as generic 'ppp?'), which is expected behavior for a custom Node.js application that doesn't match Nmap's signature database — not an indication of a filtered or closed port. A direct HTTP HEAD request confirmed the application was live and returned a 200 OK with the following notable header posture:

Header	Observed Value	Assessment
Access-Control-Allow-Origin	*	Wildcard CORS — any origin can read responses
X-Content-Type-Options	nosniff	Present — good practice
X-Frame-Options	SAMEORIGIN	Present — mitigates basic clickjacking
Strict-Transport-Security	Not present	Missing — no enforced HTTPS upgrade
Content-Security-Policy	Not present	Missing — no script-source restriction
X-Recruiting	/#/jobs	Informational disclosure (intentional Easter egg)

```
(benidict@benny)-[~/intern]
$ docker start juice
docker ps
curl -I http://127.0.0.1:3000
juice
CONTAINER ID   IMAGE                COMMAND                  CREATED        STATUS        PORTS
3e311cca455e   bkimminich/juice-shop "/nodejs/bin/node /j..." 9 days ago    Up Less than a second    0.0.0.0:3000->3000
curl: (56) Recv failure: Connection reset by peer
```

Figure 10 — Initial docker start; immediate curl attempt reset (container still initializing)

```

benidict@benny
Session Actions Edit View Help
curl: (56) Recv failure: Connection reset by peer

(benidict@benny)-[~/intern]
$ docker logs juice --tail 30
warn: "Greedy Chatbot Manipulation" challenge will not work as intended without access to http://localhost:11434/v1
warn: "AI Debugging" challenge will not work as intended without access to http://localhost:11434/v1
warn: "System Prompt Extraction" challenge will not work as intended without access to http://localhost:11434/v1
info: Check https://howto-llm.owasp-juice.shop for instructions on how to set up and configure the LLM API
info: Server listening on port 3000
info: Detected Node.js version v24.17.0 (SUCCESS)
info: Detected OS linux (SUCCESS)
info: Detected CPU x64 (SUCCESS)
info: Configuration default validated (SUCCESS)
info: Entity models 21 of 21 are initialized (SUCCESS)
info: All dependencies in ./package.json are satisfied (SUCCESS)
info: Required file server.js is present (SUCCESS)
info: Required file index.html is present (SUCCESS)
info: Required file main.js is present (SUCCESS)
info: Required file styles.css is present (SUCCESS)
info: Required file polyfills.js is present (SUCCESS)
info: Required file matching /"hacking-instructor-.+\.js$/ is present (SUCCESS)
info: Port 3000 is available (SUCCESS)
info: Domain https://www.alchemy.com/ is reachable (SUCCESS)
warn: Environment variable ALCHEMY_API_KEY is not present (WARNING)
warn: "Mint the Honey Pot" challenge will not work as intended without a valid ALCHEMY_API_KEY
warn: "Wallet Depletion" challenge will not work as intended without a valid ALCHEMY_API_KEY
info: Check https://howto-web3.owasp-juice.shop for instructions on how to set up and configure the Alchemy API
warn: Domain http://localhost:11434/v1 is not reachable (WARNING)
warn: "Chatbot Prompt Injection" challenge will not work as intended without access to http://localhost:11434/v1
warn: "Greedy Chatbot Manipulation" challenge will not work as intended without access to http://localhost:11434/v1
warn: "AI Debugging" challenge will not work as intended without access to http://localhost:11434/v1
warn: "System Prompt Extraction" challenge will not work as intended without access to http://localhost:11434/v1
info: Check https://howto-llm.owasp-juice.shop for instructions on how to set up and configure the LLM API
info: Server listening on port 3000

(benidict@benny)-[~/intern]
$ curl -I http://127.0.0.1:3000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 06 Jul 2026 13:06:01 GMT
ETag: W/"26af-19f3789217c"
Content-Type: text/html; charset=UTF-8
Content-Length: 9903
Vary: Accept-Encoding
Date: Mon, 06 Jul 2026 13:07:23 GMT
Connection: keep-alive
Keep-Alive: timeout=5

(benidict@benny)-[~/intern]
$ nmap -sV -p 3000 127.0.0.1 -oN ~/lab/scans/juiceshop-portscan.txt
nikto -h http://127.0.0.1:3000 -p ~/lab/scans/juiceshop-nikto.txt

```

Figure 11 — docker logs confirming clean startup; curl -I returning 200 OK with header set above

```
benidict@benidict-vm:~$ nmap -v -p 3000 127.0.0.1 --nmap-dir ~/lab/scans/juiceshop-nikto.txt
```

```
nmap -sV -p 3000 127.0.0.1 -oN ~/lab/scans/juiceshop-nikto.txt
nikto -h http://127.0.0.1:3000 -o ~/lab/scans/juiceshop-nikto.txt
dirsearch -u http://127.0.0.1:3000 -o ~/lab/scans/juiceshop-dirsearch.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 18:37 +0530
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000063s latency).
```

```
PORT      STATE SERVICE VERSION
3000/tcp open  pppd
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint(s):
SF-Port3000-TCP:V=7.99%I=7%D=7/F=6A4BA8A0%P=x86_64-pc-linux-gnu&r(Get
SF::Request,2866,"HTTP/1.1\x20200\x200K\r\nAccess-Control-Allow-Origin:\x2
SF:0*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEOR
SF:IGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#\job
SF:s:r\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0\
SF:s:r\r\nLast-Modified:\x20Mon,\x2006 Jul \x202026 \x2013:06:01 \x20GMT\r\nET
SF:ag:\x20W/\^26af-19f3789217c"\r\nContent-Type:\x20text/html;\x20charset
SF:=UTF-8\r\nContent-Length:\x209903\r\nVary:\x20Accept-Encoding\r\nDate:\
SF:\x20Mon,\x2006 Jul \x202026 \x2013:07:44 \x20GMT\r\nConnection:\x20close
SF:r\r\n\r\n!-\n\x20\x20-\x20Copyright\x20(c)\x202014-2026.\x20Bjoern\x2
SF:0Kimmich(\x20\x20the\x20OWASP\x20Juice\x20Shop\x20Contributors).\n\x20\x
SF:0\x20-\x20SPDX-License-Identifier:\x20MIT\n\x20\x20->\n\n<doctype>\x20
SF:.html\n<html\x20lang='en'\x20data-beasties-container>\n<head>\n\x20\x20
SF:\x20meta\x20charset='utf-8'">\n\x20\x20<title>OWASP\x20Juice\x20Shop<t
SF:title>\n\x20\x20<meta\x20name='\x20description'\x20content='\x20Probably\x20t
SF:he\x20most modern\x20and\x20sophisticated\x20insecure web\x20app\
SF:cation">\n\x20\x20<meta\x20name='\x20viewport'\x20content='\x20width=device
SF:e-width,\x20initial-scale=1">\n\x20\x20<link\x20rel='\x20preconnect'\x20
SF:href='\x20http'>\n(HELP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnectio
SF:n:\x20close\r\n\r\n")&r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nC
SF:nection:\x20close\r\n\r\n")&r(HTTPOptions,EA,"HTTP/1.1\x20204\x20No\
SF:\x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control-Allo
SF:w-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Control
SF::Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Mon,\x2006 Jul \x20
SF:\x202026 \x2013:07:44 \x20GMT\r\nConnection:\x20close\r\n\r\n")&r(RTSPrequ
SF:est,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control-Allow-Origi
SF:n:(\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DE
SF:LETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:\x200
SF:\r\nDate:\x20Mon,\x2006 Jul \x202026 \x2013:07:44 \x20GMT\r\nConnectio
SF::\x20close\r\n\r\n")&r(RPCCheck,2F,"HTTP/1.1\x20400\x20Bad\x20Request\
SF:r\r\nConnection:\x20close\r\n\r\n");
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
- Nikto v2.6.0
```

```
+ Target IP:          127.0.0.1
+ Target Hostname:    127.0.0.1
+ Target Port:        3000
+ Platform:           Unknown
```

Figure 12 — Nmap service probe against port 3000 and start of Nikto/Dirsearch scans

5.2 Nikto Findings

No server banner was disclosed (Nikto could not identify a specific backend framework version), which is a positive finding — modern frameworks that suppress version banners reduce reconnaissance value for attackers. Nikto did flag the absence of Permissions-Policy, Strict-Transport-Security, Referrer-Policy, and Content-Security-Policy headers, consistent with 5.1.

Nikto also reported `/public/`, `/.htpasswd`, `/.bash_history`, and `/.sh_history` as returning HTTP 200. These are assessed as false positives, not real findings: Juice Shop's Angular router serves `index.html` for any unmatched client-side path, so Nikto's 'file exists' heuristic (200 = present) is triggered by paths that do not correspond to actual files on the server. This is a known limitation of signature-based scanners against SPA architectures and is documented here explicitly so it is not mistaken for genuine sensitive-file exposure.

```

benidict@ber
Session Actions Edit View Help
SF:LETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:\x200
SF:\r\nDate:\x20Mon,\x2006\x20Jul\x202026\x2013:07:44\x20GMT\r\nConnection
SF::\x20close\r\n\r\n")%(RPCCheck,2F,"HTTP/1.\x20400\x20Bad\x20Request\
SF:\r\nConnection:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-07-06 18:37:45 (GMT5.5)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/dc
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/We
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/t
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/dc
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This st
+ ERROR: *** Error limit (20) reached for host, giving up. Last error: error reading HTTP response. ***
+ ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***
- STATUS: Completed 8187 requests: currently in plugin 'Nikto Tests'
- STATUS: Running average: Not enough data.
+ Scan terminated: 20 errors and 12 items reported on the remote host
+ End Time: 2026-07-06 18:39:39 (GMT5.5) (114 seconds)

+ 1 host(s) tested
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
from pkg_resources import DistributionNotFound, VersionConflict

dir3 0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/benidict/lab/scans/juiceshop-dirsearch.txt

Target: http://127.0.0.1:3000/
[18:39:40] Starting:
Cannot connect to: 127.0.0.1:3000
Task Completed

```

Figure 13 — Nikto scan against Juice Shop: header gaps flagged; SPA catch-all false positives visible

5.3 Dirsearch Findings & Availability Observation

Dirsearch reached 46% completion (5,278 of 11,460 requests) before the scan was terminated by the tool itself with a 'Too many request errors' condition, after the target began refusing connections under the 25-thread concurrent load. This occurred consistently across two independent scan attempts and is assessed as reproducible, not incidental.

Findings obtained before the interruption:

Path	Status	Assessment
/.well-known/security.txt	200	Present — good practice, security contact disclosed
/api, /api-doc, /api/*	500	Verbose error responses on ~60 API path guesses — needs manual check for stack-trace disclosure in body
/api-docs	301 → /api-docs/	Valid endpoint confirmed reachable
/assets	301 → /assets/	Standard Angular build asset directory

Availability finding: the application has no visible rate limiting or connection-queuing in front of it. A directory brute-force at a default thread count (25) was sufficient to push the single Node.js process into refusing further connections. This is a legitimate, reproducible availability weakness — not a scanning artifact — and is recorded as a finding below (see Section 7).

6. Consolidated Findings & Risk Ratings

#	Target	Finding	Risk
1	Metasploitable2	vsftpd 2.3.4 — publicly documented backdoored version (CVE-2011-2523)	Critical
2	Metasploitable2	UnrealIRCd — publicly documented backdoored version (CVE-2010-2075)	Critical
3	Metasploitable2	Tomcat Manager default credentials (tomcat/tomcat) exposed on 8180	High
4	Metasploitable2	Telnet, rsh/rlogin/rexec (512-514) — cleartext remote administration	High
5	Metasploitable2	Legacy Samba 3.X-4.X SMB service exposed	High
6	Metasploitable2	Outdated Apache 2.2.8 / PHP 5.2.4 with HTTP TRACE enabled	Medium
7	Metasploitable2	phpMyAdmin, DVWA, Mutillidae panels reachable without restriction	Medium
8	Metasploitable2	Directory indexing enabled (/icons/, /doc/); missing security headers	Low
9	Juice Shop	Wildcard CORS policy (Access-Control-Allow-Origin: *)	Medium
10	Juice Shop	No rate limiting — service degrades/refuses connections under scan load	Medium
11	Juice Shop	Verbose 500 responses on ~60 guessed API paths (unconfirmed body content)	Low-Medium
12	Juice Shop	Missing HSTS and Content-Security-Policy headers	Low

7. Impact Analysis

Metasploitable2

The backdoored vsftpd and UnrealIRCd builds (#1, #2) each represent a documented path to unauthenticated remote code execution, and their presence in enterprise-equivalent environments would constitute an immediate, critical incident — full host compromise requires no credential guessing or social engineering. The Tomcat default credentials (#3), combined with the JMX-proxy endpoints enumerated in Section 4.5, would allow an attacker to deploy arbitrary WAR files and achieve code execution on the application server. Cleartext protocols (#4) and legacy SMB (#5) primarily enable credential interception and lateral movement once any foothold exists. The co-hosted training applications (#7) expand the attack surface unnecessarily if this were a real deployment rather than a lab.

Juice Shop

The wildcard CORS policy (#9) permits any origin to make cross-origin requests and read responses, which is a meaningful risk if the API returns session-scoped or user-specific data (this was not verified in this assessment, as doing so would constitute exploitation, out of scope for Task-3). The absence of rate limiting (#10) is a genuine availability concern: this assessment itself caused a partial denial-of-service against the target using nothing more than a default-configuration directory scanner, which demonstrates the same outcome is trivially achievable by any unauthenticated actor. The verbose 500 responses (#11) warrant follow-up in Task-4 to confirm whether stack traces or internal paths are disclosed in the response body, which would elevate this from Low-Medium to at least Medium.

8. Risk Rating Summary

Risk Level	Count	Definition
Critical	2	Unauthenticated remote code execution possible with no additional steps
High	3	Direct path to compromise or credential exposure requiring minimal effort
Medium	4	Meaningful weakness requiring some additional condition to exploit
Low / Low-Medium	3	Informational or hardening gaps with limited standalone impact

9. Remediation Recommendations

9.1 Metasploitable2 (training environment — remediation shown for report completeness)

- Replace vsftpd 2.3.4 and UnrealIRCd with current patched builds; in a real environment, remove any service whose provenance/build integrity cannot be verified.
- Disable Tomcat Manager remote access or, at minimum, replace default credentials and restrict /manager/ and /host-manager/ to an authenticated management network.
- Disable Telnet, rsh, rlogin, and rexec; replace with SSH for all remote administration.
- Upgrade Samba to a currently supported release and disable SMBv1 if not required.
- Patch Apache/PHP to current stable releases; disable the HTTP TRACE method; disable directory indexing on production web roots.
- Remove or access-restrict phpMyAdmin, DVWA, and Mutillidae if this host pattern were ever mirrored outside a lab.

9.2 Juice Shop

- Replace the wildcard CORS policy with an explicit allow-list of trusted origins.
- Implement request rate limiting (e.g. express-rate-limit or a reverse-proxy layer such as Nginx with limit_req) to prevent both malicious and incidental service degradation.
- Review the ~60 API paths returning HTTP 500 to confirm error responses do not leak stack traces, file paths, or framework version details; return generic error bodies in production.
- Add HSTS and a Content-Security-Policy header appropriate to the Angular build's script/style sources.

10. Conclusion

This assessment achieved its Task-3 objectives: network assets were discovered and confirmed reachable, open ports and running services were enumerated with versions, outdated and misconfigured services were identified on both targets, and web-layer weaknesses were scanned and documented without exploitation. Metasploitable2 confirmed its role as an intentionally critical-risk legacy training target, while Juice Shop — despite being a comparatively modern, well-maintained application — still surfaced concrete, reproducible findings, most notably its lack of rate limiting under active scanning.

Recommended next steps: proceed to Task-4 for controlled exploitation and deeper web-application testing (manual verification of the CORS and 500-response findings on Juice Shop should be prioritized), and treat this report's findings list as the baseline against which Task-4 results are measured.

Appendix A — Evidence File Index

File	Description
host-discovery.txt	nmap -sn sweep of 192.168.56.0/24
metasploitable-portscan.txt	nmap -sV -p- full port/service scan of 192.168.56.103
metasploitable-nikto-80.txt / -8180.txt	Nikto scans of Metasploitable2 ports 80 and 8180
metasploitable-dirsearch-80.txt / -8180.txt	Dirsearch scans of Metasploitable2 ports 80 and 8180
juiceshop-portscan.txt	nmap -sV -p 3000 scan of Juice Shop container
juiceshop-nikto.txt	Nikto scan of Juice Shop (127.0.0.1:3000)
juiceshop-dirsearch.txt	Dirsearch scan of Juice Shop (partial — terminated by target under load)